# SECURITY AUDIT REPORT

http://altoro.testfire.net/

ANALYST
**mohamed guizani**

## ENVIRONMENT INSIGHT

| | |
|---|---|
| IP Address | 34.149.87.120 |
| Tech Stack | Angular / Node.js |
| Server | Nginx |
| Open Ports | 80, 443, 8080 |

## SECURITY SURFACE SCORE

**8.2/10**

## SECURITY HEADERS AUDIT

| | | | |
|---|---|---|---|
| Content-Security-Policy | **MISSING** | Strict-Transport-Security | **MISSING** |
| X-Frame-Options | **MISSING** | X-Content-Type-Options | **PRESENT** |
| Referrer-Policy | **MISSING** | | |

# DETAILED VULNERABILITY AUDIT

**TOTAL OF 18 FINDINGS DETECTED**

| SEVERITY | VULNERABILITY IDENTIFICATION | EVIDENCE SNAPSHOT |
|---|---|---|
| MEDIUM | **NMAP: 443/TCP OPEN SSL/HTTP APACHE TOMCAT/COYOTE JSP ENGINE 1.1**<br>DISC-E4DC16E41C4C | 443/tcp open ssl/http Apache Tomcat/Coyote JSP engine 1.1 |
| MEDIUM | **SECURITY HEADER MISCONFIGURATION (VIA FEROXBUSTER)**<br>DISC-71D397A5E159 | http://altoro.testfire.net/images/header_pic.jpg |
| HIGH | **CROSS-SITE SCRIPTING**<br>DISC-CD46B013E953 | https://altoro.testfire.net/search.jsp?query=<hexstrikeXSSTest123> Payload reflected via GET form |
| CRITICAL | **SQL INJECTION DETECTED**<br>DISC-230BCAED00CC | Parameter: query, uid |
| HIGH | **STORED XSS DETECTED**<br>DISC-C4018DD5D7FB | Payload injected via comment field |
| MEDIUM | **SESSION MANAGEMENT VULNERABILITY**<br>DISC-9B40CAF2B25E | Set-Cookie header analysis |
| HIGH | **AUTHENTICATION BYPASS (AUTH WEAKNESSES)**<br>DISC-6D91A7A093D0 | Auth flow heuristic analysis |
| MEDIUM | **SECURITY HEADER MISCONFIGURATION**<br>DISC-8554CFE85962 | Response headers inspection |
| MEDIUM | **MISSING CONTENT SECURITY POLICY (CSP)**<br>DISC-3D6C7844D660 | Target: http://altoro.testfire.net/ Missing header: content-security-policy |
| LOW | **MISSING X-CONTENT-TYPE-OPTIONS**<br>DISC-FE2312EDE7EE | Target: http://altoro.testfire.net/ Missing header: x-content-type-options |

| SEVERITY | VULNERABILITY IDENTIFICATION | EVIDENCE SNAPSHOT |
|---|---|---|
| LOW | **MISSING X-FRAME-OPTIONS**<br>DISC-2E1221384535 | Target: http://altoro.testfire.net/ Missing header: x-frame-options |
| LOW | **MISSING REFERRER-POLICY**<br>DISC-DDD53C6F7220 | Target: http://altoro.testfire.net/ Missing header: referrer-policy |
| LOW | **MISSING PERMISSIONS-POLICY**<br>DISC-D770F5929133 | Target: http://altoro.testfire.net/ Missing header: permissions-policy |
| MEDIUM | **COOKIE MISSING SECURE FLAG**<br>DISC-5B9E6ADB05A3 | Target: http://altoro.testfire.net/ Set-Cookie header lacks 'Secure' attribute |
| LOW | **COOKIE MISSING SAMESITE ATTRIBUTE**<br>DISC-B2802FF5240D | Target: http://altoro.testfire.net/ Set-Cookie header lacks 'SameSite' attribute |
| MEDIUM | **INSECURE TRANSPORT (HTTP)**<br>DISC-DAAD93F0204C | Target URL: http://altoro.testfire.net/ |
| INFO | **SERVER HEADER INFORMATION DISCLOSURE**<br>DISC-57ED64554542 | Target: http://altoro.testfire.net/ Server: Apache-Coyote/1.1 |
| INFO | **TECHNOLOGY DETECTED: JAVA/TOMCAT**<br>DISC-B4435FACA8F8 | Source: Headers/Cookies/Body Matching "Java/Tomcat" |